

COMPTE RENDU : TP 4.1 – MISE EN PLACE D'UN PARE-FEU PFSense ET SEGMENTATION DU LABORATOIRE

1. Introduction

L'objectif de ce TP était de transformer un environnement réseau "Host-Only" totalement ouvert, où toutes les machines (Kali, Ubuntu, Windows) communiquaient sans restriction, en un réseau contrôlé. Pour ce faire, nous avons introduit un pare-feu pfSense agissant comme une passerelle sécurisée entre un réseau externe (WAN) et un réseau interne (LAN).

2. Configuration réseau des machines virtuelles (VMs)

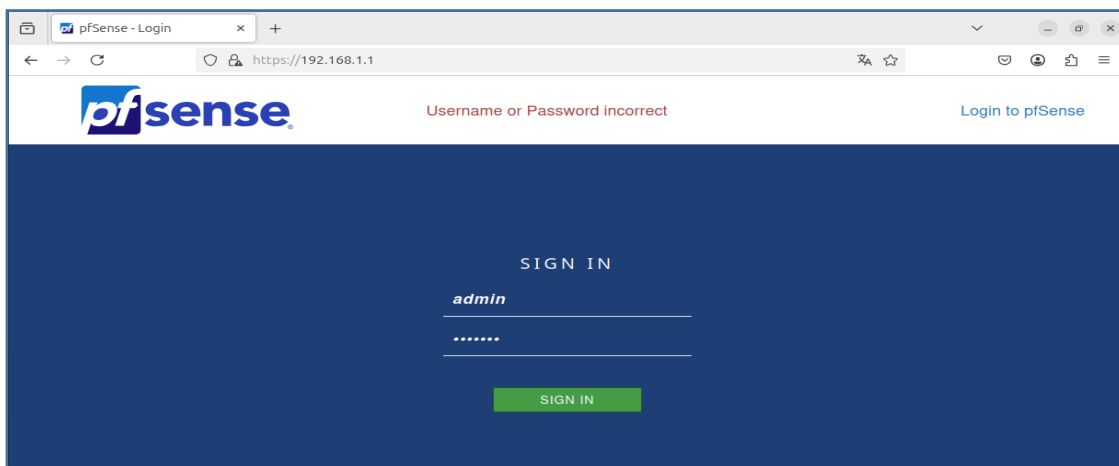
La première étape a consisté à configurer l'infrastructure dans VirtualBox. La machine pfSense a été équipée de deux cartes réseau :

- **Interface 1 (WAN) :** Mode NAT (simulant l'accès Internet).
- **Interface 2 (LAN) :** Mode Host-Only (réseau interne sécurisé).

Les machines Ubuntu et Windows ont ensuite été basculées sur ce même réseau Host-Only pour être isolées derrière le pare-feu.

3. Interface d'administration pfSense

Une fois l'installation terminée, l'administration du pare-feu s'est faite via l'interface web à l'adresse `https://192.168.1.1` depuis une machine du réseau interne (Ubuntu ou Windows).



4. Création des règles de filtrage

Par défaut, pfSense autorise tout le trafic sortant sur le LAN. Pour répondre aux exigences du TP, nous avons restreint ce flux en modifiant la règle par défaut et en créant une règle spécifique pour le protocole HTTP.

Paramètres de la règle créée :

- **Action** : Pass
- **Interface** : LAN
- **Protocole** : TCP
- **Port** : 80 (HTTP)

The screenshot shows the 'firewall_rules_edit.php?if=lan' page in a web browser. The configuration is as follows:

- Interface:** LAN
- Address Family:** IPv4
- Protocol:** TCP
- Source:** any (Source Address is empty)
- Source Port Range:** (other) From (other) To (both empty)
- Destination:** LAN net (Destination Address is empty)
- Destination Port Range:** HTTP (80) From HTTP (80) To (both empty)

Buttons for 'Hide Advanced', 'Apply', 'Save', and 'Cancel' are visible at the bottom.

Firewall / Rules / LAN

The firewall rule configuration has been changed.
The changes must be applied for them to take effect.

Apply Changes

Floating WAN LAN

Rules (Drag to Change Order)											
	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☒	✓ 1 / 1.39 MiB	*	*	*	LAN Address	443 80	*	*		Anti-Lockout Rule	
☐	✓ 0 / 44 KiB	IPv4 *	LAN net	*	*	*	*	none		Default allow LAN to any rule	
☐	✓ 0 / 0 B	IPv6 *	LAN net	*	*	*	*	none		Default allow LAN IPv6 to any rule	
☐	✓ 0 / 0 B	IPv4 TCP	*	*	LAN net	80 (HTTP)	*	none			

Add Add Delete Save Separator

Explication de la règle :

- **Pourquoi elle fonctionne :** Elle autorise spécifiquement les paquets TCP sortants provenant du réseau local vers n'importe quelle destination, à condition que le port de destination soit le 80.
- **Ce qu'elle autorise :** La navigation web non sécurisée (HTTP) et les requêtes vers des serveurs web externes utilisant ce port.
- **Ce qu'elle bloque :** Tout le reste du trafic non explicitement autorisé par une autre règle (politique de "Deny All" implicite une fois la règle par défaut désactivée), notamment le protocole ICMP (Ping) et les autres ports TCP/UDP.

5. Résultats des tests de fonctionnement

Pour vérifier l'efficacité de notre politique de sécurité, nous avons effectué des tests depuis la machine Ubuntu :

1. **Test HTTP :** La commande `curl http://example.com` a réussi.
2. **Test ICMP (Ping) :** La commande `ping 8.8.8.8` a échoué.
3. **Simulation d'attaque (Scan) :** La commande `nmap -sS 8.8.8.8` n'a pas fonctionné correctement.

```
willy@will:~$ ping 8.8.8.8
ping: connect: Le réseau n'est pas accessible
willy@will:~$
```

```
(tsafack@tsafack)-[~]
$ nmap -sS 8.8.8.8
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-28 17:07 +0200
setup_target: failed to determine route to 8.8.8.8
WARNING: No targets were specified, so 0 hosts scanned.
Nmap done: 0 IP addresses (0 hosts up) scanned in 0.08 seconds
```

Interprétation : Ces résultats confirment que le pare-feu remplit son rôle. Même si la machine Ubuntu était compromise, un attaquant ne pourrait pas utiliser d'outils de scan externe ou communiquer avec un serveur de commande (C&C) sur des ports non autorisés.

6. Propositions d'améliorations

Pour renforcer davantage la sécurité de cette architecture, je propose les améliorations suivantes :

1. **Restreindre au HTTPS uniquement :** Modifier la règle pour autoriser le port 443 au lieu du port 80 afin de forcer les flux chiffrés et bloquer le HTTP non sécurisé.
2. **Filtrage granulaire des ports :** Bloquer précisément des ports sensibles (comme le SSH ou le Telnet) vers l'extérieur pour éviter l'exfiltration de données.

3. **Ajout d'une zone DMZ :** Créer une troisième interface isolée pour héberger des services accessibles de l'extérieur (serveur web, mail) sans qu'ils ne puissent initier de connexion vers le réseau interne LAN.

7. Conclusion

Ce TP m'a permis de comprendre que la sécurité commence par le réseau. Un pare-feu bien configuré limite drastiquement la surface d'attaque et permet de reprendre le contrôle sur les flux entrants et sortants, rendant le mouvement latéral d'un attaquant beaucoup plus complexe.